

Narrativa explicativa GQM + PRAGMATIC aplicada a indicadores SIEM

O cómo evitar que el cuadro de mando SIEM se convierta en un poema numérico sin trama.

1. Métricas con propósito, no por deporte

Hablar de métricas SIEM sin un propósito claro es como medir la lluvia en milímetros sin preguntarse si conviene sacar el paraguas. El marco combinado GQM + PRAGMATIC intenta evitar precisamente eso: que los KPIs se conviertan en colecciones de números decorativos, impecables en Excel e irrelevantes en la realidad.

GQM nos obliga a empezar por donde casi nunca empezamos: los objetivos. No “qué podemos medir”, sino “qué queremos cambiar”. Reducir el tiempo de detección y respuesta, cumplir NIS2 con algo más que voluntad, proteger OT y 5G, aprovechar la IA sin perder el control y, sobre todo, traducir todo ello a un idioma que entienda tanto el CISO como el ministro de turno.

2. De los objetivos (G) a las preguntas (Q)

Una vez formulados los objetivos a nivel país, sector u organización, el marco exige preguntas incómodamente concretas. Si el objetivo es reducir el impacto de incidentes graves, la pregunta ya no es “¿tenemos SIEM?”, sino “¿cuánto tardamos realmente en detectar y contener un ataque que importa?”. Si el objetivo es cumplir NIS2, la cuestión no es “¿tenemos un procedimiento de notificación?”, sino “¿qué porcentaje de incidentes notificamos dentro de plazo y con evidencias decentes?”.

Estas preguntas actúan como filtro: todo aquello que no ayuda a responderlas puede ser valioso, pero no es prioritario. A partir de ellas se derivan métricas que, con suerte, miden algo que alguien, en algún consejo o gabinete, realmente quiere saber.

3. De las preguntas (Q) a las métricas (M)

La parte “M” de GQM es donde el SIEM entra en escena con sus millones de eventos, su MTDD, su MTTR y sus sofisticadas curvas de falsos positivos. La diferencia es que ahora no se trata de coleccionar métricas por inercia, sino de seleccionar unas pocas que:

- Se puedan obtener de forma fiable y repetible.
- Estén vinculadas a decisiones concretas (dimensionar el SOC, invertir en automatización, reforzar la monitorización OT).
- Sean comprensibles para personas que no viven dentro de un terminal.

MTDD y MTTR dejan de ser cifras de vanidad y se convierten en termómetros de resiliencia. La cobertura de activos críticos y de técnicas ATT&CK deja de ser un detalle técnico y se convierte en indicador de cuánto riesgo “ciego” asumimos. Los plazos de notificación dejan de ser materia de compliance y pasan a ser una medida de diligencia nacional.

4. PRAGMATIC: el comité de ética de las métricas

Por muy ingeniosa que sea una métrica, si no supera el filtro PRAGMATIC, no merece aspirar al rango de KPI estratégico. Los criterios funcionan como una especie de comité de ética que se pregunta:

- ¿Esta métrica anticipa algo o llega siempre tarde (Predictivo)?
- ¿Le importa a alguien que tome decisiones (Relevante)?
- Si se mueve, ¿sabemos qué hacer (Accionable)?
- ¿Mide realmente lo que dice medir (Genuino)?
- ¿La entiende alguien que no diseñó el SIEM (Significativo)?
- ¿Está suficientemente bien definida (Preciso)?
- ¿Llega a tiempo como para cambiar algo (Oportuno)?
- ¿Es robusta frente a sesgos e intereses cruzados (Independiente)?
- ¿Cuesta menos de lo que aporta (Rentable)?

El resultado no es infalible, pero sí higiénico: obliga a justificar la presencia de cada métrica en el cuadro de mando y ofrece una base común para discutir prioridades.

5. De la teoría a la práctica: cuadros de mando y decisiones

Con los objetivos claros, las preguntas bien formuladas y las métricas evaluadas, el resto es, en apariencia, sencillo:

- Definir un conjunto de métricas “estrella” para el nivel nacional y para cada sector.
- Incorporarlas a encuestas, herramientas de reporting y acuerdos de nivel de servicio.
- Alimentar con ellas un Índice Global de Madurez (IGM) y modelos de ROI que no sean pura literatura.

En realidad, lo complicado no es tanto calcular MTTD o estimar pérdidas evitadas, como decostumbrarse a indicadores que “siempre se han usado” pero no superan el filtro PRAGMATIC. El marco no prohíbe nada, pero invita a una dieta más saludable: menos numerología, más trazabilidad.

6. Epílogo: métricas al servicio de la resiliencia

Si todo sale bien, el resultado no será un PowerPoint más vistoso, sino decisiones mejores: inversiones justificadas, prioridades más claras, menos sorpresas desagradables en titulares y en boletines oficiales. El SIEM seguirá generando ruido, pero al menos el ruido estará domesticado por un conjunto de métricas que saben por qué existen.

Y si, además, algún día un responsable de política pública puede decir con fundamento que el país detecta antes, responde mejor y notifica con más rigor que hace cinco años gracias a estas métricas, entonces GQM y PRAGMATIC habrán cumplido su parte del trato.

Fin de la narrativa.